

Data Retention and Disposal Policy

Board Room · Version 1.0 · Effective 1 August 2026 · Next scheduled review 1 August 2027
Owner and sole operator: cam.carp14@gmail.com

1. Purpose and scope

This policy defines how long Board Room retains data, how that data is disposed of, and the technical mechanisms that enforce both. It covers all data held by the application, including financial account and transaction data received through the Plaid API.

Board Room is a private, single-user application. Its only user is its owner, who is also the only individual whose personal or financial data it holds. It has no customers, no employees and no contractors, and it does not process data on behalf of any other person or organisation. The scope of this policy is therefore one production environment, one database and one user account.

2. Roles and responsibilities

The owner is solely responsible for the operation of the application, for the enforcement of this policy, and for responding to any deletion request. No other party has access to the production systems. Contact for all matters covered here: cam.carp14@gmail.com.

3. Data inventory and retention periods

Retention is by purpose, not by calendar: financial data is kept only while it is useful to the person it describes, and is destroyed immediately on request. No category of data is retained for a secondary purpose after deletion, and none is retained for analytics, resale, model training or advertising, because none of those activities take place.

Data	Source	Where it is held	Retention	Disposal
Transactions — date, amount, description, merchant, category	Plaid <code>/transactions/sync</code> , or a CSV export from the bank	Managed PostgreSQL (Supabase), encrypted at rest	Until the owner deletes them, or the user account is deleted	Hard DELETE ; no soft-delete flag, no archive table
Account balances and metadata (name, type, last four digits)	Plaid <code>/accounts/get</code>	Not stored. Held in page memory only	Duration of the page view	Discarded when the page closes; nothing to erase
Plaid access token and item identifier	Plaid <code>/item/public_token/exchange</code>	Managed PostgreSQL, in a table with row-level security enabled and <i>no policy</i> , all privileges revoked from browser-facing roles	Until the institution is disconnected, or the user account is deleted	Revoked at Plaid via <code>/item/remove</code> , then deleted from the database

Data	Source	Where it is held	Retention	Disposal
Authentication data — email address, password hash	Entered by the owner	Supabase Auth	Life of the account	Deleted with the account
Application data — lists, notes, budgets, dates	Entered by the owner	Managed PostgreSQL	Until deleted by the owner	Hard DELETE

Bank credentials are never retained, because they are never received. They are entered into Plaid Link, which authenticates with the financial institution directly; this application receives only an access token, and never a username, password or one-time code.

4. Disposal procedures

Deletion is a function of the application rather than a manual database operation, so it is available on demand and leaves nothing behind:

- **Disconnecting an institution** calls Plaid's `/item/remove`, ending Plaid's access to that institution, and deletes the stored access token in the same operation. No further data can be retrieved for that institution afterwards.
- **Removing an account's transactions** deletes those rows outright. There is no recycle bin, no tombstone and no archived copy.
- **Deleting the user account** removes every associated row: each table holding user data declares its user reference on `delete cascade`, so erasure is a database-enforced consequence rather than a cleanup step that could be forgotten.
- **Balances** are never written to storage by design — a stored balance goes stale silently and is then read as current — so there is no balance data to dispose of.

Disposal is immediate and irreversible in the production database. Copies may persist in the hosting providers' encrypted point-in-time backups until those age out on the providers' own schedules; they are not accessible to the application and are used for no purpose other than disaster recovery.

5. Technical enforcement

The controls below are properties of the system rather than practices to be remembered, which is what makes this policy enforced rather than merely defined:

- Row-level security is enabled on every table holding user data, scoped so a signed-in session can read only rows belonging to that user.
- Plaid access tokens sit in a table with row-level security enabled and *no policy at all*, with all privileges revoked from the anonymous and authenticated database roles. They are readable only by the server-side function that uses them, and are never transmitted to the browser.
- The Plaid client secret exists only as an environment variable on the server-side functions. It is not in the source repository and not in the client bundle; automated secret scanning fails any build that would publish it.

- All data in transit is protected by TLS 1.2 or better. Data at rest is encrypted by the database provider using AES-256.
- Access to the systems that store or process this data — the database, the hosting platform, the source repository and the Plaid dashboard — is limited to the sole owner and protected by multi-factor authentication.
- Automated tests run on every build assert the retention-relevant properties directly: that balances are never persisted, that disconnection calls `/item/remove`, and that the token table grants nothing to browser-facing roles. A change that broke one of them would fail the build.

6. Service providers

Three processors are used, each under its own published terms: **Plaid Inc.** (connectivity to financial institutions), **Supabase** (database and authentication, SOC 2 Type II) and **Netlify** (hosting and server-side functions, SOC 2 Type II). No data is shared with any other party. There is no analytics provider, no advertising network, no data broker, and no tracking of any kind.

7. Legal and regulatory compliance

The application holds the personal and financial data of one individual — its owner — and does not process the data of any other data subject, sell data, or share it for cross-context behavioural advertising. Where data protection laws such as the California Consumer Privacy Act or the General Data Protection Regulation would apply, the rights they confer — access, correction, portability and erasure — are exercisable at any time by the owner directly within the application, and erasure is honoured immediately by the mechanisms in section 4. Financial data obtained through Plaid is used solely to present the owner's own account activity back to them, consistent with the permitted use granted at the time of connection.

8. Review

This policy is reviewed at least annually, and additionally whenever the application's handling of data changes — a new data source, a new storage location, or a change to how anything is deleted. The public-facing privacy notice that summarises it is published at <https://board-room.netlify.app/privacy> and is revised in the same change.

Version	Date	Change	Approved by
1.0	1 August 2026	Initial policy.	Owner and sole operator

Approved and in force as of 1 August 2026.

Board Room — Owner and Sole Operator · cam.carp14@gmail.com